

HOW TO PREPARE FOR A SOC 2 AUDIT

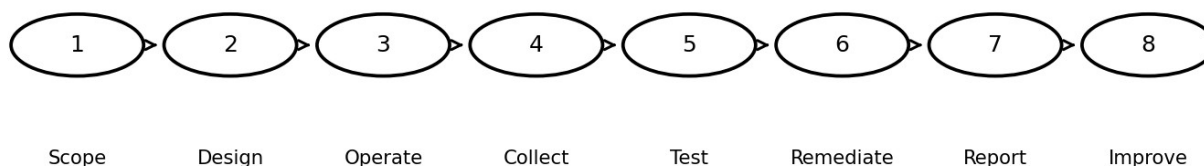
*A Practical Guide to Readiness, Controls, Evidence, Testing, and
Continuous Compliance*

For managers, GRC analysts, security professionals, engineers, control owners, and
service-organization leaders

Alberto (Al) Leiva

Version 1.0 - July 2026

SOC 2 readiness and assurance lifecycle



Evidence must demonstrate that controls are designed, implemented, and operating as described.

CC BY-NC-SA 4.0

Important professional notice

This manual helps service organizations prepare responsibly for a SOC 2 examination. It explains readiness and evidence practices but does not replace the authoritative AICPA guidance, the judgment of a qualified CPA firm, or legal and professional advice.

Management owns the controls and assertions. Only a qualified independent CPA firm can issue a SOC 2 report.

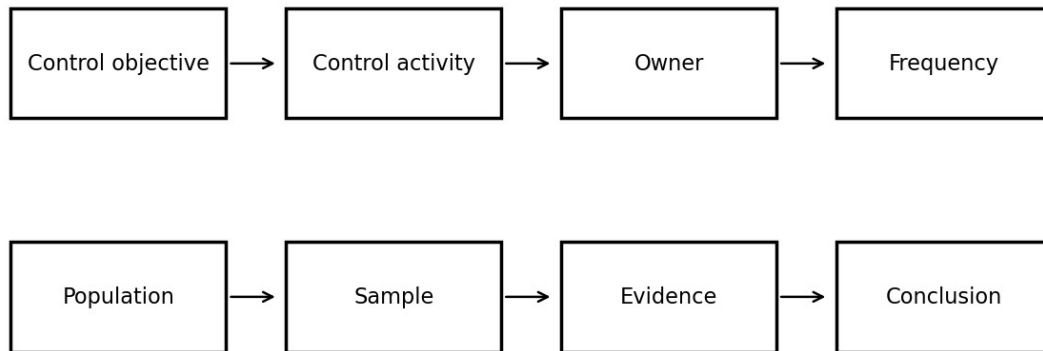
How to use this manual

- Read Chapters 1-5 before selecting scope and criteria.
- Use Chapters 6-16 to design controls and evidence.
- Use Chapters 17-20 to manage the examination and continuous improvement.
- Adapt all examples to your service commitments, risks, systems, and auditor guidance.

Table of contents

- 1. Understanding SOC 2
- 2. Type 1 and Type 2 reports
- 3. Governance and readiness ownership
- 4. Defining scope and system boundaries
- 5. Trust Services Criteria and control mapping
- 6. Risk assessment
- 7. Policies and standards
- 8. Logical access controls
- 9. Change management and secure development
- 10. Security operations and incident response
- 11. Availability and business continuity
- 12. Confidentiality, privacy, and data lifecycle
- 13. Vendor and subservice organization management
- 14. Evidence management
- 15. Population, sampling, and exceptions
- 16. The system description
- 17. Working with the service auditor
- 18. Common readiness failures
- 19. 30/60/90-day readiness plan
- 20. Production-ready checklist and portfolio project

Evidence chain



1. Understanding SOC 2

SOC 2 is an examination of controls at a service organization relevant to security, availability, processing integrity, confidentiality, or privacy. A service auditor performs the examination; management prepares the system description, makes assertions, owns the controls, and provides evidence. SOC 2 is not a product certification and it is not a one-time technical scan.

- Security is the common criterion and is included in every SOC 2 engagement.
- Availability, processing integrity, confidentiality, and privacy are selected when relevant to commitments and system requirements.
- The scope should match the services, system components, locations, people, processes, data, and subservice organizations that matter to users.

2. Type 1 and Type 2 reports

A Type 1 report addresses the design and implementation of controls at a specified date. A Type 2 report also addresses operating effectiveness over a stated review period. Customers commonly request Type 2 because it provides evidence of sustained operation.

- Choose the report type based on customer needs, maturity, available operating history, and the auditor's advice.
- Do not describe a control as operating for a period unless the organization can produce complete, consistent evidence.
- Plan enough time for remediation before the examination period begins.

3. Governance and readiness ownership

SOC 2 readiness is a cross-functional program. Security may coordinate it, but evidence and control operation usually depend on engineering, IT, human resources, legal, privacy, finance, facilities, customer operations, and executive leadership.

- Name an executive sponsor, program lead, control owners, evidence providers, system-description owner, and remediation owners.
- Create a RACI matrix and a recurring readiness meeting.
- Escalate missed evidence, overdue remediation, and uncontrolled scope changes early.

4. Defining scope and system boundaries

A defensible scope begins with the service commitments made to customers and the system used to deliver those commitments. Avoid scoping only the production application while ignoring supporting identities, cloud services, support processes, development pipelines, monitoring, or key vendors.

- Document products and services in scope.
- Identify infrastructure, software, people, procedures, and data.
- Identify physical and logical boundaries.
- List subservice organizations and choose the carve-out or inclusive presentation with the auditor.
- Document complementary user entity controls that customers must perform.

5. Trust Services Criteria and control mapping

Map risks and controls to the applicable Trust Services Criteria without treating the criteria as a checklist of prescribed technologies. Controls should respond to the organization's actual risks, commitments, and system requirements.

- Start with risks and commitments, then identify controls.
- Map each control to one or more criteria and explain the relationship.
- Avoid duplicate controls with different names unless the activities are genuinely distinct.
- Use points of focus as implementation considerations, not as separate mandatory controls.

Category	Purpose
Security	Protect information and systems against unauthorized access, use, disclosure, damage, or disruption.
Availability	Support availability commitments and system requirements.
Processing integrity	Support complete, valid, accurate, timely, and authorized processing.
Confidentiality	Protect information designated as confidential.

Privacy	Manage personal information according to commitments and recognized privacy criteria.
---------	---

6. Risk assessment

A SOC 2 program needs a documented process to identify objectives, threats, vulnerabilities, fraud risks, changes, third parties, and potential impacts. The risk assessment should inform control design and should be refreshed after material changes.

- Define risk criteria and ownership.
- Connect risks to controls and treatment decisions.
- Include cloud, identity, software supply chain, privacy, availability, and insider risks.
- Record accepted risks and management approval.

7. Policies and standards

Policies establish management expectations; standards and procedures explain how work is performed. A policy that is not communicated, approved, reviewed, and supported by operating evidence is weak audit evidence.

- Maintain version, owner, approver, effective date, and review date.
- Train affected personnel.
- Connect policy statements to implemented controls.
- Remove obsolete or contradictory documents.

8. Logical access controls

Access controls should cover workforce users, privileged users, service accounts, applications, agents, contractors, and third parties across the full lifecycle.

- Document onboarding, role changes, and termination.
- Require strong authentication and protect privileged access.
- Review access periodically.
- Monitor dormant, shared, emergency, and non-human accounts.
- Retain evidence of requests, approvals, provisioning, reviews, and removals.

9. Change management and secure development

Change controls should show that changes are authorized, tested, reviewed, traceable, and separated from production approval where appropriate.

- Use tickets or pull requests with approvals.
- Protect production branches and deployment credentials.

- Document emergency changes and retrospective review.
- Connect vulnerability remediation and dependency updates to change records.
- Retain deployment evidence for the entire examination period.

10. Security operations and incident response

Security monitoring, vulnerability management, event triage, incident response, and lessons learned should operate as a connected process.

- Define severity and escalation.
- Retain vulnerability scans, remediation records, alerts, cases, incident timelines, and post-incident reviews.
- Test the incident-response plan.
- Track recurring issues and corrective actions.

11. Availability and business continuity

When availability is in scope, controls should address capacity, resilience, backups, recovery, monitoring, and continuity commitments.

- Define recovery objectives that support customer commitments.
- Test backups and restoration, not merely backup completion.
- Exercise business continuity and disaster recovery plans.
- Document incidents, downtime, capacity trends, and corrective actions.

12. Confidentiality, privacy, and data lifecycle

Confidentiality protects information designated as confidential. Privacy addresses personal information throughout collection, use, retention, disclosure, and disposal. The two categories overlap but are not interchangeable.

- Inventory sensitive and personal data.
- Define classification, retention, deletion, encryption, and access rules.
- Review data-sharing and subprocessor arrangements.
- Document privacy notices, choices, requests, and incident procedures when privacy is in scope.

13. Vendor and subservice organization management

Organizations remain responsible for understanding dependencies on cloud providers, processors, support vendors, and other subservice organizations.

- Perform risk-based due diligence before onboarding.
- Review contracts and security commitments.
- Obtain and evaluate relevant assurance reports.

- Track complementary subservice organization controls.
- Monitor changes, incidents, performance, and termination.

14. Evidence management

Good evidence is relevant, complete, accurate, attributable, time-bound, and protected from alteration. Screenshots alone are often weak because they may not show the population, date range, owner, approval, or operating history.

- Define evidence requirements for each control before the period begins.
- Preserve populations and system-generated exports.
- Record source, owner, date, scope, and reviewer.
- Protect confidential evidence and control auditor access.
- Use consistent naming and an evidence index.

Evidence attribute	Question
Relevant	Does it directly demonstrate the control?
Complete	Does it cover the full period or population?
Accurate	Can it be reconciled to a reliable source?
Attributable	Can the performer, approver, system, and date be identified?
Protected	Is access restricted and integrity preserved?

15. Population, sampling, and exceptions

For recurring controls, the auditor may select samples from a complete population. Management should be able to produce the full population and explain how it was generated.

- Reconcile population counts to source systems.
- Do not curate or remove failed items.
- Investigate exceptions and identify root cause.
- Distinguish isolated evidence gaps from control failures.
- Document remediation and whether additional testing is needed.

16. The system description

Management prepares the description of the service organization's system. It should be accurate, balanced, and consistent with actual operations and customer commitments.

- Describe services, boundaries, infrastructure, software, people, procedures, data, and significant events.
- Explain applicable criteria, control activities, subservice organizations, and complementary user entity controls.

- Avoid marketing language that overstates capabilities.
- Update the description when the system changes.

17. Working with the service auditor

Select a qualified CPA firm with relevant industry and technology experience. Agree on scope, timing, criteria, report type, subservice treatment, milestones, evidence methods, and communication protocols.

- Provide accurate information and disclose known incidents or control issues.
- Clarify requests early rather than submitting unrelated documents.
- Track open requests, questions, exceptions, and management responses.
- Management owns readiness; the auditor must remain independent.

18. Common readiness failures

Frequent problems include unclear scope, missing populations, controls that exist only in policy, inconsistent approvals, evidence created after the fact, stale access, untested recovery, and unsupported claims in the system description.

- Perform a pre-period gap assessment.
- Run mock evidence collections.
- Test controls before relying on them.
- Freeze neither the system nor the evidence process; instead use change control.
- Treat repeat exceptions as systemic problems.

19. 30/60/90-day readiness plan

A practical roadmap helps the organization move from fragmented controls to an auditable operating model.

- Days 1-30: confirm business need, select preliminary scope, assign owners, inventory systems, map commitments, and identify critical gaps.
- Days 31-60: finalize control matrix, remediate high-risk gaps, build evidence procedures, draft the system description, and perform mock testing.
- Days 61-90: operate controls consistently, resolve exceptions, validate populations, complete readiness review, and confirm examination timing with the auditor.

20. Production-ready checklist and portfolio project

The final readiness decision should be evidence-based. For a safe portfolio project, learners can create a fictional service organization, scope statement, risk register, control matrix, evidence index, sample access review, incident tabletop record, and sanitized system-description outline.

- Never upload confidential customer evidence, real employee data, production screenshots, secrets, or actual audit workpapers to a public repository.
- Label fictional artifacts clearly.
- Explain assumptions, limitations, and how each control reduces a stated risk.

Final readiness checklist

- ☐ Business need and intended report users confirmed
- ☐ Qualified CPA firm selected
- ☐ Type 1 or Type 2 decision documented
- ☐ System and services in scope defined
- ☐ Applicable criteria selected and justified
- ☐ Subservice organizations identified
- ☐ Complementary user entity controls documented
- ☐ Risk assessment current
- ☐ Control owners assigned
- ☐ Policies approved and communicated
- ☐ Logical access lifecycle evidenced
- ☐ Change management evidenced
- ☐ Vulnerability and incident processes evidenced
- ☐ Backup, recovery, and continuity tested
- ☐ Vendor monitoring operating
- ☐ System description accurate
- ☐ Evidence populations complete
- ☐ Exceptions investigated and remediated
- ☐ Management assertion reviewed
- ☐ Secure evidence-sharing method agreed
- ☐ Readiness decision approved

Official references

[AICPA SOC for Service Organizations - overview](#)

[AICPA SOC 2 resources and authoritative guide](#)

[AICPA SOC 2 reporting guide](#)

[2017 Trust Services Criteria with revised points of focus - 2022](#)

Use the current AICPA materials and the service auditor's instructions. Do not reproduce proprietary criteria or audit workpapers without permission.

License and attribution

Copyright © 2026 Alberto (Al) Leiva. Licensed under Creative Commons Attribution-NonCommercial-ShareAlike 4.0 International.